

Denegación de Servicio (DoS)

Seguridad en Sistemas Informáticos — Tema 3.4

José Luis Martínez

Universidad de Castilla-La Mancha

Curso 2026/27

- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Botnets
- 6 Herramientas y ejemplos

Taxonomía de un Ataque

- Footprinting
- Escaneo /
- Fingerprinting
- Enumeration
- Access
- Elevación Privilegios
- Pivoting / Mov. Lateral
- Covering
- Persistencia/Back doors
- DoS
- Recopilación de Información / Open Source Intelligence

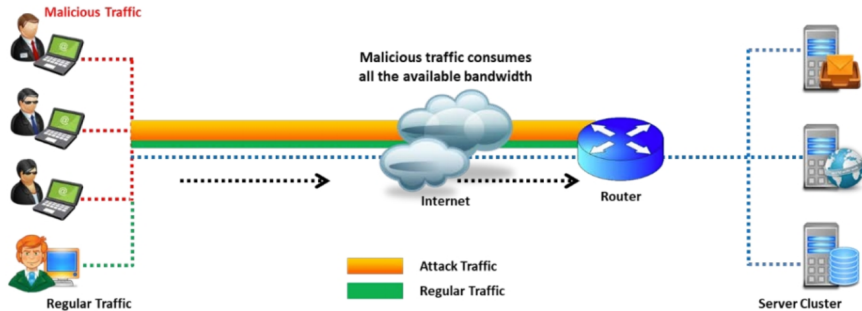
Taxonomía de un Ataque

- Credenciales
- Exploiting
- Postexplotación
- Esta unidad nos centramos aquí
- Recopilación de Información / Open Source Intelligence

- Tras la fase de recopilación de información en la que se han identificados los activos de la organización, los dos principales vectores de ataque son:
- Ataques de acceso (objetivo principal de un Pentesting)
- Rompiendo o consiguiendo credenciales válidas
- Explotando vulnerabilidades no corregidas (tema siguiente)
- Denegación de Servicio (DoS)
- DoS

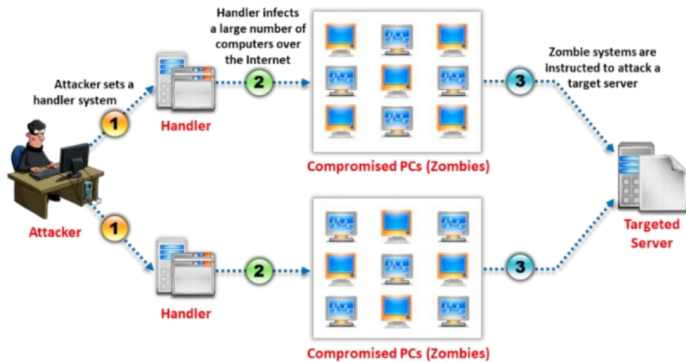
- Los ataques DoS intentan que un recurso de red (host, la red de interconexión) reduzca, restrinja o deje de funcionar para los usuarios legítimos
- Una de las opciones más comunes para perpetrar este ataque es la inundación (flooding) de peticiones para saturar la capacidad de respuesta del recurso
- DoS

Introducción



- Los ataques DoS Distribuidos (DDoS) persiguen el mismo objetivo que los DoS pero el impacto es mucho mayor al igual que su probabilidad de éxito, ya que parten de una multitud de sistemas comprometidos (zombies), normalmente, a través de una botnet. Estos bots o zombies son controlados por el atacante a través de un sistema de Command and Control (C&C)
- DoS

Introducción



El objetivo final de un ataque DoS puede ser:

- Consumo de recursos
- Consumo de ancho de banda, disco, uso de CPU, etc.
- Ataques físicos de destrucción o alteración de componentes
- Destrucción de ficheros de configuración o programas del host
- Leer: interesante
- Caída de whatsapp, Facebook e Instagram:
- John Graham, el CTO de Cloudflare avisó a través de su cuenta de Twitter que cinco minutos antes de que los DNS de Facebook dejaran de funcionar, vimos un aumento de las BGP [en su mayoría retiradas de ruta] en los sistemas autónomos de Facebook.
- Sin embargo, la hipótesis más extendida es que Facebook se borró a sí mismo por accidente, según explica el CEO de Cloudflare, Matthew Prince. "La explicación más probable es que las rutas de Internet de la empresa (BGP) fueron retiradas por error durante el mantenimiento".
- DoS

Tipos de ataques de DoS:

- Ataques de buffer overflow
- Ataques permanentes o phishing



- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

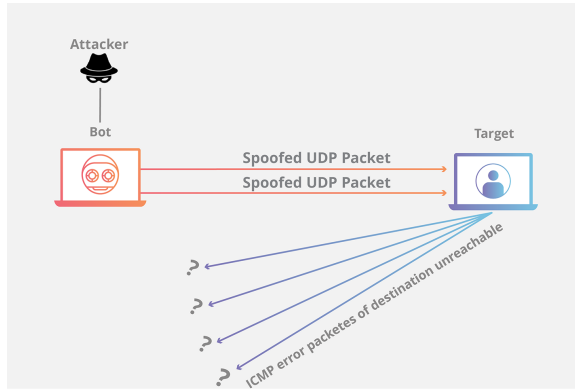
- 1 Introducción
- 2 Ataques volumétricos**
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Botnets
- 6 Herramientas y ejemplos

Ataques volumétricos

- El objetivo de estos ataques es abusar del ancho de banda entre el objetivo (normalmente el servidor) y los usuarios legítimos.
- Se apoyan en protocolos no orientados a la conexión y se basan en inundar la red con este tipo de paquetes y conseguir que el objetivo no sea capaz de responder ni a éstos paquetes ni a los legítimos
- Se pueden abordar también de manera distribuida (DDoS)
- Tipos:
 - Inundación UDP / ICMP
 - Inundación ICMP
 - Smurf
 - DoS

- El objetivo es enviar a un alto ratio de paquetes UDP a varios servidores con la dirección IP origen falseada (spoofed) con la dirección de la víctima.
- Estos servidores hacen de amplificadores puesto que reenviarán las respuestas a la IP de la víctima, consiguiendo que ésta se sature y deje de funcionar
- Ejemplo1 y Ejemplo2
- DoS

Inundación UDP



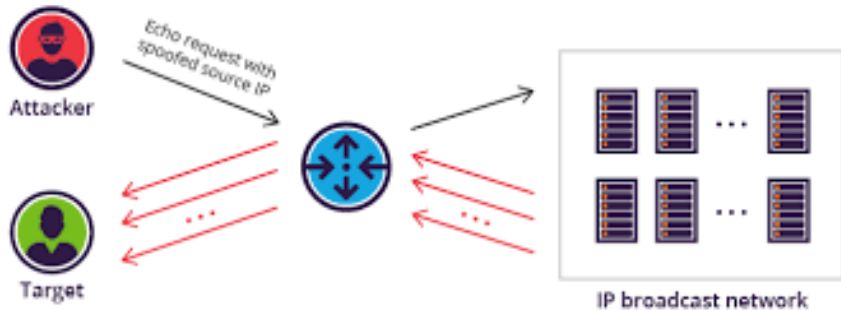
Inundación ICMP

- El objetivo es enviar a un alto ratio de paquetes ICMP echo reply (ping) a la dirección de la víctima.
- También se puede hacer rebotado y amplificado (Smurf)



- Es similar al anterior, pero en este caso el atacante falsifica la dirección origen del paquete ICMP, con la IP del objetivo/víctima .
- De esta manera todas las respuestas le llegan a él
- También se puede amplificar enviándolo a la dirección de broadcast con la IP origen de la víctima para que todas las repuestas vayan a ésta
- DoS

Smurf



Amplificación DDoS — DNS, NTP y Memcached

- Los ataques de amplificación combinan IP spoofing con servicios UDP que generan respuestas mucho mayores que la petición original.
- Factores de amplificación
- DNS amplification — ratio $\sim 28\text{--}54\times$ (petición ANY a resolver abierto)
- NTP amplification — ratio $\sim 556\times$ (comando monlist, CVE-2013-5211)
- Memcached — ratio $\sim 51.000\times$ (mayor amplificación conocida, UDP/11211)
- SSDP — ratio $\sim 30\times$ (UPnP en dispositivos domésticos)
- SNMP v2 — ratio $\sim 650\times$ (GetBulk a community 'public')
- CharGEN — ratio $\sim 358\times$ (servicio legacy en puerto 19/UDP)
- Cómo funciona (DNS como ejemplo)
- 1. Atacante falsifica la IP origen $\rightarrow$ pone la IP de la víctima

Amplificación DDoS — DNS, NTP y Memcached

- 2. Envía petición DNS de tipo ANY a un resolver abierto
- 3. El resolver responde con paquetes grandes → a la IP de la víctima
- → Poca ancho de banda del atacante genera tráfico masivo sobre la víctima
- Detección y mitigación
- BCP38 / uRPF: filtrado de IP spoofing en origen (operadores ISP)
- Cerrar resolvers DNS abiertos y deshabilitar NTP monlist
- Rate-limiting de respuestas DNS (NXDOMAIN/ANY) en el resolver

- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo**
- 4 Buffer overflow
- 5 Botnets
- 6 Herramientas y ejemplos

Ataques consumo

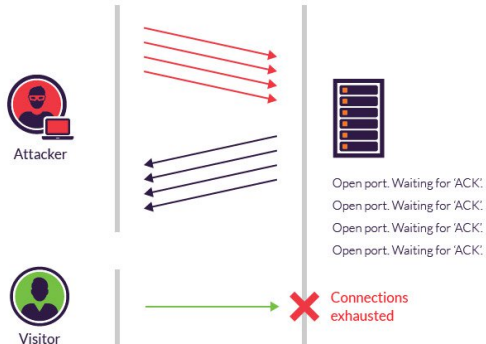
- Este tipo de ataques de DoS o DDoS se basan en el consumo desmesurado de los recursos de la máquina, tales como memoria, CPU, etc derivados del uso de las conexiones, por ejemplo, del protocolo TCP.
- Tipos
- Inundaciones SYN
- Fragmentación
- Ataques de capa de aplicación
- DoS

Inundación SYN

- El atacante envía una gran cantidad de solicitudes SYN al servidor objetivo (víctima) con direcciones IP de origen falsas
- El ataque crea conexiones TCP incompletas que utilizan los recursos de red de la máquina objetivo.
- A partir del método TCP three-way handshake. En un ataque SYN, el atacante explota este método de la siguiente manera: primero, el atacante envía una solicitud de TCP SYN falsa al servidor de destino y cuando el servidor devuelve un SYN / ACK en respuesta a la solicitud del cliente (atacante), el cliente nunca envía una respuesta ACK y deja al servidor esperando para completar la conexión
- DoS

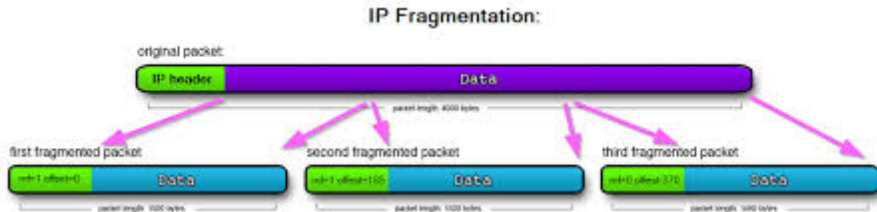
- El host víctima un seguimiento de las conexiones parcialmente abiertas, mientras espera los paquetes de respuesta ACK en una cola de escucha
- Un host malicioso puede explotar el host enviando muchas solicitudes SYN al host a la vez.
- Cuando la cola está llena, el sistema no puede abrir nuevas conexiones hasta que elimine algunas entradas de la cola de conexión (debido al tiempo de espera del protocolo de enlace).
- DoS

Inundación SYN



Fragmentación

- En este tipo de ataques el atacante intenta gastar la memoria de la víctima, fragmentando un paquete muy grande en muchos más pequeños para que, cuando la víctima reconstruya el paquete original
- El impacto es mucho mayor si se incrementa la tasa de envío de paquetes
- DoS



Ataques de capa de aplicación

- En este caso, se usan protocolos de capa de aplicación como HTTP.
- El atacante envía alto ratio de paquetes GET o POST a la víctima para saturar los recursos de ésta y que no atienda peticiones legítimas
- Un ejemplo de este ataque es slowloris en el que el atacante abre muchas conexiones HTTP sin esperar a que se completen y alcanzar el máximo de conexiones concurrentes que soporta la víctima
- DoS

Ataques de capa de aplicación

Normal HTTP Request - Response Connection



Slowloris DDoS Attack



Complete HTTP Request - Response Cycle



Incomplete HTTP Requests



HTTP Rapid Reset y Ataques Lentos de Capa 7

- Ataques consumo / Aplicación
- Slowloris y variantes de ataques lentos
- Slowloris — abre conexiones HTTP y envía cabeceras incompletas lentamente
- Slow POST / RUDY — envía el body de un POST en bytes sueltos cada pocos segundos
- Slow Read — anuncia ventana TCP de recepción cero; el servidor queda bloqueado
- → Herramienta: slowhttptest (cubre los tres vectores anteriores)
- HTTP/2 Rapid Reset — CVE-2023-44487
- Ataque DDoS más grande de la historia: 398 Mpps (Google, Cloudflare, AWS, 2023)
- Explota el multiplexado de HTTP/2: el atacante abre y cancela (RST_STREAM) streams
- a velocidad extrema sin esperar respuesta, agotando el servidor con coste mínimo
- El servidor procesa el reset pero ya ha asignado recursos al stream

HTTP Rapid Reset y Ataques Lentos de Capa 7

- Afectó a todos los grandes: Google (>398M rps), Cloudflare, Amazon
- → Mitigación: parches en servidores HTTP/2 (nginx, Apache, IIS, Go net/http)
- Otras herramientas capa 7
- LOIC / HOIC — HTTP flood clásico, fácilmente bloqueable por IP
- GoldenEye — HTTP flood con keep-alive y cabeceras aleatorias
- PyLoris — implementación Python de Slowloris con control fino
- [blog.cloudflare.com](https://blog.cloudflare.com/http2-rapid-reset-deconstructing-the-record-breaking-attack/) — 'HTTP/2 Rapid Reset: deconstructing the record-breaking attack'

- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

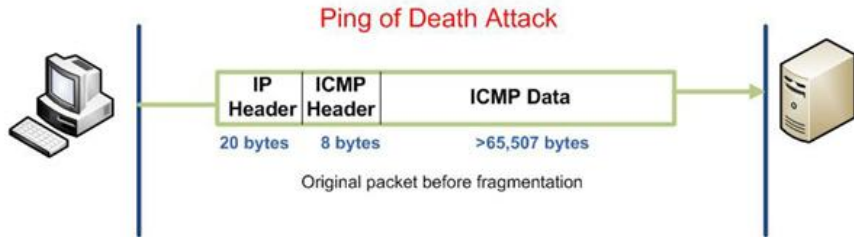
- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow**
- 5 Botnets
- 6 Herramientas y ejemplos

Buffer overflow

- Otra técnica de DoS es conseguir que el sistema objetivo crashee (se rompa) debido a una mala programación o gestión de la memoria, los denominados buffer overflow
- Un buffer overflow no es más que cuando una petición excede los límites de memoria, ya sea de una variable, de un proceso, de la pila, y produce un comportamiento anómalo. Un buffer overflow bien construido puede conseguir que el flujo de ejecución del programa salte a donde el atacante quiere, por ejemplo, hacia un payload que ejecute una Shell (exploiting) o, simplemente desbordando la dirección de memoria hacia una zona de memoria inexistente o una operación aleatoria, hace que el programa deje de funcionar y la aplicación o el sistema operativo (si es a nivel de kernel) se caiga produciendo una DoS
- DoS

- Un atacante intenta bloquear, desestabilizar o congelar el sistema mediante el envío de paquetes mal formados o de gran tamaño con un simple comando ping.
- En este caso, el atacante envía un paquete que tiene un tamaño de 65,538 bytes al servidor web de destino. Este tamaño del paquete excede el límite de tamaño prescrito por RFC 791 IP, que es de 65,535 bytes
- El proceso de reensamblaje por parte del sistema receptor puede causar que el sistema se bloquee.
- DoS

Ping de la muerte



Crashing de aplicaciones

- Existen bugs en aplicaciones que, permiten a un usuario exceder los límites de la aplicación y, haciendo que ésta deje de funcionar.
- Por ejemplo, si un servicio ftp mal programado, no controla la entrada de datos del usuario, puede ocurrir que éste exceda los límites de la variable que recoge la entrada de datos. Si ocurre esto, el atacante estaría sobrescribiendo datos de otras variables contiguas o incluso instrucciones.
- Cuando el programa lee esas posiciones sobrescritas (en caso de variables) o ejecuta las instrucciones machacadas (en caso de instrucciones) se produce un crash de la aplicación ya que no se mantiene la lógica de la aplicación y se produce el famoso “pantallazo azul” en sistemas Windows o el crash en Unix, lo que es una DoS
- DoS

Crashing de aplicaciones



- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

Permanentes o phlashing

- Este tipo de ataques se dirigen exclusivamente al hardware y causan daños irreversibles.
- Sabotean el hardware del sistema, lo que requiere que la víctima reemplace o reinstale el componente dañado.
- Otra variante a este tipo de ataques es aquellos en los que, a través de un fallo de seguridad o una conexión directa en un dispositivo, se consigue la administración remota en las interfaces de administración y, una vez con acceso, se pueden borrar ficheros de configuración, formatear el sistema, borrar aplicaciones, etc.
- DoS

- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Botnets**
- 6 Herramientas y ejemplos

- Una botnet es una red de zombies o robots y que son controladas por un pastor.
- Se usan para escaneos, envío de spam, phishing o campañas de DoS
- Los bots son aplicaciones de software que ejecutan tareas automatizadas a través de Internet
- Hay diferentes tipos de bots, como bots de Internet, bots de IRC y bots de chatter.

- El atacante realiza una exploración para encontrar máquinas vulnerables disponibles en una red; investigando direcciones IP al azar del rango de IP de la red objetivo y comprueba si dispone de vulnerabilidades.
- Al encontrar una máquina vulnerable, irrumpe en ella e intenta infectarla instalando en ella el mismo código malicioso (exploit)
- Una vez que una máquina ha sido comprometida, ésta descarga el código malicioso, por ejemplo, si el atacante coloca una copia de la botnet en un servidor propiedad del atacante y transfiere al sistema vulnerable recién explotado. Este software dispone de un mecanismo de secuencias de comandos, para que el atacante y el bot se puedan comunicar (C&C).
- DoS

- <https://unaaldia.hispasec.com/2022/08/google-neutraliza-el-mayor-ataque-ddos-https-registrado-hasta-la-fecha.html>

Google neutraliza el mayor ataque DDoS HTTPS registrado hasta la fecha

22 agosto, 2022 Por Nicolás Moret Yáñez — Deja un comentario

Un cliente de **Google Cloud Armor** sufrió un ataque de denegación de servicio distribuido (**DDoS**) a través del protocolo HTTPS que alcanzó los **46 RPS** (millones de peticiones por segundo), lo que lo convierte en el mayor registrado de su tipo.



- El anonimato te lo ofrece ToR (dark web)... aunque bueno, no hay nada seguro, la red ToR también tiene vulnerabilidades o malas configuraciones de los nodos por parte de los clientes
- La idea reside en lanzar las peticiones masivas a través de la red ToR para garantizar el anonimato
- Herramientas:
 - ddositor
 - DoS

Mitigaciones y Contramedidas DoS / DDoS

- Contramedidas
- En el servidor / host
 - SYN Cookies — responde al SYN con cookie sin reservar recursos hasta el ACK
 - Rate limiting — limitar conexiones por IP / segundo a nivel de firewall o kernel
 - Timeouts agresivos — reducir tiempo de espera de conexiones semi-abiertas
 - Deshabilitar servicios UDP amplificadores (NTP monlist, CharGEN, SNMP v1/v2)
- En la red / ISP
 - BCP38 / uRPF — filtrado de origen: bloquea paquetes con IP spoofed
 - BGP Blackholing — anunciar al upstream que descarte tráfico hacia una IP víctima
 - Anycast routing — distribuir el tráfico malicioso entre múltiples PoPs globales
 - → Así mitiga Cloudflare: absorbe el tráfico en ~300 PoPs antes de llegar al origen

Mitigaciones y Contramedidas DoS / DDoS

- Servicios especializados anti-DDoS
- Scrubbing centers — centros que limpian el tráfico antes de enviarlo al origen
- CDN + WAF — Cloudflare, Akamai, AWS Shield, Azure DDoS Protection
- RTBH (Remote Triggered Black Hole) — blackhole selectivo con comunidades BGP
- Detección y monitorización
- Análisis de flujos NetFlow / IPFIX: detectar volúmenes anómalos
- Umbral de pps (paquetes/segundo): alerta si supera la línea base habitual
- SIEM con correlación de eventos de red + IDS (Snort / Suricata / Zeek)

- Ataques
 - Ataques de buffer overflow
 - Ataques permanentes o phlashing

- 1 Introducción
- 2 Ataques volumétricos
- 3 Ataques de consumo
- 4 Buffer overflow
- 5 Botnets
- 6 Herramientas y ejemplos**

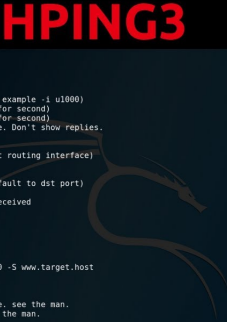
Ataque DoS de tipo flooding

- Hping3

- `Hping3 -c 15000 -d 120 -S -w 64 -p 80 -flood -rand-source IP`
- `Hping3 -S -p 135 -flood IP`
- `Hping3 -udp -flood -spooof IP IP`

- slowloris

Ataque DoS de tipo flooding



```
Foot@kali:~$ hping3 --help
usage: hping3 host [options]
  -h --help      show this help
  -v --version   show version
  -c --count     packet count
  -i --interval  wait (uX for X microseconds, for example -i u1000)
  --fast        alias for -i u10000 (10 packets for second)
  --faster      alias for -i u1000 (100 packets for second)
  --flood       sent packets as fast as possible. Don't show replies.
  -n --numeric  numeric output
  -q --quiet     quiet
  -I --interface interface name (otherwise default routing interface)
  -V --verbose   verbose mode
  -D --debug     debugging info
  -z --bind      bind ctrl+z to ttl (default to dst port)
  -Z --unbind    unbind ctrl+z
  --beep        beep for every matching packet received

Mode
  default mode  TCP
  -0 --rawip    RAW IP mode
  -1 --icmp     ICMP mode
  -2 --udp      UDP mode
  -8 --scan     SCAN mode.
                  Example: hping --scan 1-30,70-90 -S www.target.host
  -9 --listen   listen mode

IP
  -a --spoof     spoof source address
  --rand-dest    random destination address mode. see the man.
  --rand-source  random source address mode. see the man.
  -t --ttl       ttl (default 64)
  -N --id        id (default random)
  -W --winid     use win* id byte ordering
  -r --rel       relativize id field (to estimate host traffic)
  -f --frag      split packets in more frag. (may pass weak acl)
  -x --morefrag  set more fragments flag
  -u --dontfrag  set don't fragment flag
```

Ataque DoS de tipo flooding

■ Metasploit

```
Auxiliary/dos/tcp/sysflood
```

```
Auxiliary/dos/http/slowloris.py
```

```
Auxiliary/dos/Windows/rdp/ms12_020_maxchannelsid
```

■ Nmap NSE:

```
nmap -script http-slowloris -max-parallelism 400 <target>
```

```
nmap -script smb-flood.nse -p445 <host>
```

■ Yersinia

```
yersinia dhcp -attack 1
```

```
yersinia stp -attack 2
```

```
sudo yersinia cdp -attack 1
```


Ataques DoS de tipo buffer overflow

- Metasploit
 - Search dos (se pueden encontrar múltiples exploits DoS para diferentes aplicaciones)
- Exploit-db
 - <https://www.exploit-db.com/?type=dos&platform=windows&tag=3>
 - (exploits DoS para sistemas Windows con exploit en metasploit)
 - <https://www.exploit-db.com/?type=dos&platform=linux>
 - (exploits DoS para aplicaciones Linux)

- Utiliza la herramienta hping3 para hacer un ataque DoS al servidor web alojado en la máquina metasploitable2
 - Utiliza metasploit y su módulo synflood para hacer un DoS al servicio ssh de la máquina metasploitable
- Nota: Si te atreves, puedes probar a hacer un DoS al router de tu casa

DoS Flooding



DoS Buffer Overflow

- A partir de esta máquina **Windows XP** en la que he instalado un servidor ftp vulnerable
- Realiza un fingerprinting del servicio ftp
- Localiza un exploit en metasploit para hacer un ataque DoS a dicho servicio
- Realiza el ataque y comprueba como la aplicación crashea

DoS Buffer Overflow



Usaré la aplicación Mikrotik disponible aquí:

- <https://www.exploit-db.com/exploits/24968>
- Utiliza metasploit para realizar un ataque de tipo DoS



DoS Windows RDP

- A partir del win7 y/o win XP
- Determina si son vulnerables a esta vulnerabilidad DoS:
 - <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2012/ms12-020>
- Puerto 3389
- auxiliary:

```
msf ms12_020_maxchannelsids
```



¡Gracias!

Seguridad en Sistemas Informáticos — Tema 3.4